

NAME: DEVIKA N	SRN: PES1UG24AM080	SECTION: B
-----------------------	---------------------------	-------------------

Date: 03-10-2026

Lab 3: Component Modelling & Architectural Pattern Selection

Architecture Selection

We chose **Layered Architecture** for the **Patient Health Record Consent Management System**.

Architectural Choice

A three-layer architecture was selected:

- The Presentation layer holds the User Interface used by patients, doctors and clinic administrators.
- The Business layer holds the Consent Manager, Authentication, Audit Logger and Notification Service.
- The Data layer holds the Consent & Health Record Database and the Audit Log Database.

Each layer calls only the layer below it through the interfaces shown in the component diagram.

Reasons

- Single enforcement point for consent rules: Every grant, revocation and record access (FR-001 to FR-003) must pass through the Business layer, where expiry, revocation and MFA checks run before any data is released. The UI can never reach the data directly, so a consent check cannot be bypassed.
- Strong consistency for instant revocation and auditing: FR-002 requires revoked access to be denied within 5 seconds, and NFR-001 requires a complete append-only audit trail. A layered design keeps consent state in one authoritative data layer and sends every event through one Audit Logger. Microservices would add eventual-consistency and network-latency problems and heavy operational overhead for a system of this size, and plain Client-Server gives no internal separation of business rules from data.

Security:

- Layers create clear trust boundaries. Only the Data layer talks to the databases, so AES-256 encryption at rest and TLS 1.2+ in transit (NFR-002) are enforced in one place, at the consent and record queries interface.
- The Authentication component, which handles MFA, sits in the Business layer, so a doctor's password alone never grants record access (FR-003).
- The Audit Log Database exposes only an append-only write API, so no component can modify or delete audit entries.

Performance Benefit

The layers are deployed together, so calls between them are local, low-latency calls rather than network hops across many separate services. This helps the consent check meet the 5-second revocation target, and the Business layer can cache consent status and invalidate the cache the moment a patient revokes access. The trade-off is some per-request layer overhead and scaling as one unit, which is acceptable at clinic scale.